UNITÀ 1 · CYBERSECURITY

# Verifica Unità 1: soluzioni e griglia

Risposte corrette, punteggi e indicazioni di correzione. Totale 100 punti; voto in decimi = punti ÷ 10, arrotondato al mezzo voto (60 punti = 6). Nelle risposte aperte conta il ragionamento: una risposta diversa da quella attesa ma motivata e corretta vale i punti pieni.

## 1. Scelta multipla · 18 punti

| Dom. | Risposta corretta | Punti | Note |
|---|---|---|---|
| a | **Integrità** | 3 | Il dato è stato modificato senza autorizzazione. Tranello: "non ha rubato dati" confonde sicurezza e riservatezza. |
| b | **la probabilità che un account venga violato** | 3 | La MFA è preventiva: abbassa P. Non cambia il numero di e-mail di phishing ricevute; nessuna misura azzera il rischio. |
| c | **il SIEM** | 3 | Il SOAR esegue in automatico i playbook; l'EDR sta sul singolo PC; il WAF protegge il web. |
| d | **Il threat hunter** | 3 | L'analista L1 lavora sugli allarmi esistenti; il pentester attacca con autorizzazione. |
| e | **Un WAF** | 3 | Packet filter e stateful guardano IP, porte e stato, non il contenuto HTTP. Il WAF è una difesa in più, non sostituisce il codice corretto. |
| f | **A01 Broken Access Control** | 3 | È un IDOR: il server non controlla che la spedizione sia del cliente della sessione. |

## 2. Vero o falso · 12 punti (1,5 ciascuna)

| N. | V/F | Motivo |
|---|---|---|
| 1 | **V** | La NIS2 porta la sicurezza al livello della direzione (approvazione, sorveglianza, formazione, responsabilità). |
| 2 | **F** | Si trasferisce il danno economico, non la responsabilità: il titolare del trattamento risponde comunque. |
| 3 | **F** | Quello è il falso positivo; il falso negativo è un attacco reale senza allarme. |
| 4 | **F** | Base64 è una codifica: chiunque la inverte senza chiave. |
| 5 | **V** | Era il punto d'ingresso del caso Officine Rossi della lezione 3. |
| 6 | **V** | Dal 2021 l'XSS è dentro A03 Injection. |
| 7 | **F** | L'accesso abusivo (art. 615-ter c.p.) è reato anche senza danni e anche se poi si avvisa. |
| 8 | **V** | |

## 3. Il registro dei rischi · 12 punti

a) R1 **12 Medio** · R2 **16 Alto** · R3 **15 Alto** · R4 **8 Medio** · R5 **6 Basso**. 1 punto per riga (valore e livello entrambi corretti; R3 e R4 sono sulle soglie: verificare che lo studente le applichi).

b) **=SE(E2>=15;"Alto";SE(E2>=8;"Medio";"Basso"))** (2 punti). SE annidati corretti ma con soglie sbagliate: 1 punto. Virgola al posto del punto e virgola o IF in inglese: nessuna penalità.

c) Polizza: **trasferire** · spegnere il server FTP inutilizzato: **evitare** · lasciare R5 e scriverlo: **accettare** (1 punto ciascuno). Se lo studente scrive "accettare" senza notare che va documentato, punto pieno comunque: il testo lo dice già.

d) **Abbassano I**: il ransomware può arrivare lo stesso (P invariata), ma si ripristina senza pagare (2 punti: 1 per I, 1 per il perché). Premiare chi nota che con la doppia estorsione il danno da pubblicazione dei dati resta.

## 4. Gli attaccanti e la kill chain · 10 punti

a) 1 **hacktivista** · 2 **insider** · 3 **gruppo statale (APT)** · 4 **cybercriminale** (affiliato RaaS). 1 punto ciascuno.

b) 1 **comando e controllo** · 2 **armamento** · 3 **azioni sull'obiettivo** · 4 **consegna** · 5 **installazione** · 6 **sfruttamento**. 1 punto ciascuno. Accettare i nomi inglesi (Command and Control, Weaponization, Actions on Objectives, Delivery, Installation, Exploitation). Manca la ricognizione: chi lo osserva spontaneamente merita una nota positiva.

## 5. MITRE ATT&CK · 6 punti

1 **Initial Access** (T1566 Phishing) · 2 **Credential Access** (T1110 Brute Force) · 3 **Lateral Movement** (T1021.001) · 4 **Persistence** (T1136 Create Account) · 5 **Privilege Escalation** (T1068) · 6 **Impact** (T1486 e T1490). 1 punto ciascuno; i codici non sono richiesti. Restano inutilizzate Reconnaissance, Execution, Discovery, Exfiltration. Per la riga 4 accettare anche Privilege Escalation se lo studente motiva che l'account creato è di amministratore.

## 6. Leggere un log · 10 punti

a) **203.0.113.45** (1). Indizi, 1 punto ciascuno fino a 2: sei tentativi falliti in circa 4 secondi, ritmo da programma e non da persona; nomi utente diversi e generici (admin, administrator, backup) provati dallo stesso IP; alle 2 di notte.

b) **Sì**: accesso riuscito come **fbianchi alle 02:14:05** (2 punti; 1 se manca l'ora o l'account).

c) **ALTO per 203.0.113.45** (6 falliti, poi accesso come fbianchi) e **MEDIO per 192.0.2.77** (4 falliti di gneri, nessun accesso); **nessun allarme** per 198.51.100.8 (nessun fallito) e 198.51.100.12 (un solo fallito, poi l'accesso di lverdi). 1 punto per allarme, 1 per gli IP senza allarme.

d) Tattica **Credential Access**, tecnica **Brute Force (T1110)** (1); contromisura **MFA sulla VPN** (1). Accettare anche "password spraying" (T1110.003) per i nomi utente diversi. Il blocco dopo N tentativi o il limite di frequenza riduce il rischio ma non lo impedisce con la password giusta: mezzo punto.

## 7. Risposta all'incidente e NIS2 · 10 punti

a) A **contenimento** · B **eradicazione** · C **preparazione** · D **ripristino** · E **identificazione** · F **lezioni apprese**. 1 punto ciascuno.

b) Al **CSIRT Italia**, presso l'ACN. **Preallarme entro venerdì alle 10:00** (24 ore), **notifica entro domenica alle 10:00** (72 ore), **relazione finale entro un mese** dalla notifica. 3 punti: 1 per il destinatario, 2 per le tre scadenze (1 se ne sbaglia una). Le ore contano anche nel fine settimana.

c) **Sì: al Garante per la protezione dei dati personali, entro 72 ore**, per il GDPR (1 punto). È una notifica distinta da quella NIS2.

## 8. Firewall, segmentazione, VPN · 8 punti

a) **Regola 2**: gli Ospiti raggiungono anche Uffici e Magazzino; va scritta Ospiti → Internet, TCP 80, 443 e DNS, consenti. **Regola 5**: un portale violato aprirebbe connessioni verso gli Uffici; va tolta o cambiata in

blocca (se il portale ha bisogno di un dato interno, solo una porta verso un solo server). 2 punti per regola: 1 per l'errore motivato, 1 per la correzione.

b) 1 **VPN con MFA** (accettare anche accesso zero trust alla singola applicazione) · 2 **WAF** · 3 **segmentazione con VLAN** e regole tra i segmenti · 4 **firewall stateful**. 1 punto ciascuno.

## 9. OWASP Top 10 · 8 punti

| N. | Categoria (1 punto) | Correzione (1 punto) |
|---|---|---|
| 1 | **A03 Injection** | Query parametrizzate: `PreparedStatement` con segnaposto `?`; validare il formato del codice; messaggi d'errore generici. |
| 2 | **A02 Cryptographic Failures** | Salvare solo un hash lento con sale (bcrypt, Argon2), mai la password; non basta un hash veloce come SHA-256 da solo. |
| 3 | **A07 Identification and Authentication Failures** | Limite di tentativi o rallentamento progressivo, MFA, avviso all'utente; registrare i falliti (A09) perché il SOC li veda. |
| 4 | **A06 Vulnerable and Outdated Components** | Inventario delle dipendenze, aggiornamento della libreria, controllo automatico delle vulnerabilità note (caso Log4Shell). |

Basta il codice o il nome della categoria. Correzione generica ("mettere più sicurezza", "usare un antivirus"): 0 punti.

## 10. Capture the Flag ed etica · 6 punti

a) 1 **forensics** · 2 **reverse** · 3 **crypto** · 4 **web**. 1 punto ciascuno.

b) 2 punti se contiene: **non continuo a guardare, non lo provo su altri, non lo diffondo**; **lo segnalo in privato alla scuola** (docente, segreteria, che avvisa il fornitore), cioè divulgazione responsabile; perché i voti sono dati personali di altri e andare avanti sarebbe accesso abusivo. 1 punto se manca il perché. Collegamento atteso: è un IDOR (A01).

Documento riservato al docente. Per studenti con PDP o PEI: si possono fornire l'elenco delle fasi della kill chain per l'esercizio 4b e la tabella dei livelli già impostata per l'esercizio 3, oppure togliere l'esercizio 10b, riproporzionando il punteggio.